



Khoa Luan Tot Nghiep Chat Bao Mat

Tài liệu học tập (Trường Đại học Văn Hiến)



messages.pdf_cover_qr_code_label

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC VĂN HIẾN
KHOA CÔNG NGHỆ THÔNG TIN**



**ĐỀ TÀI
HỆ THỐNG CHAT BẢO MẬT (MÃ HÓA AES/RSA)**

GVHD: Th.S CAO HOÀNG KHẢI

SVTH: PHẠM VĂN TÙNG - 221A010682

QUÁCH THỊ BẢO TRÂM - 221A011089

TP. HỒ CHÍ MINH – 2025

LỜI CẢM ƠN

Trong suốt quá trình thực hiện đồ án tốt nghiệp, nhóm chúng em đã nhận được sự hỗ trợ và hướng dẫn tận tình từ nhiều cá nhân và tổ chức. Nhóm chúng em xin gửi lời cảm ơn chân thành và sâu sắc nhất đến tất cả mọi người đã đồng hành cùng chúng em trong suốt quá trình này.

Trước tiên, nhóm chúng em xin bày tỏ lòng biết ơn sâu sắc đến Thầy ThS. CAO HOÀNG KHẢI – Giảng viên hướng dẫn đồ án tốt nghiệp của chúng em. Thầy đã dành nhiều thời gian quý báu để hướng dẫn, chỉ bảo và định hướng cho nhóm trong từng giai đoạn thực hiện đồ án. Những góp ý và sự chỉ dẫn tận tình của Thầy đã giúp nhóm chúng em vượt qua được những khó khăn và hoàn thành đồ án một cách tốt nhất có thể.

Chúng em xin trân trọng cảm ơn Ban Giám hiệu Trường Đại học Văn Hiến, Ban Chủ nhiệm Khoa Công nghệ Thông tin cùng toàn thể quý Thầy Cô trong Khoa đã tạo điều kiện thuận lợi, truyền đạt kiến thức và kỹ năng chuyên môn trong suốt quá trình học tập tại trường.

Chúng em cũng xin cảm ơn gia đình, bạn bè và những người thân đã luôn ủng hộ, động viên và tạo mọi điều kiện thuận lợi để chúng em có thể tập trung hoàn thành đồ án trong thời gian quy định.

Do kiến thức và kinh nghiệm còn hạn chế, đồ án không tránh khỏi những thiếu sót. Chúng em rất mong nhận được sự góp ý, nhận xét của quý Thầy Cô để đồ án được hoàn thiện hơn.

Chúng em xin chân thành cảm ơn!

Tp.Hồ Chí Minh, ngày tháng năm 2025

Sinh viên thực hiện

PHẠM VĂN TÙNG

QUÁCH THỊ BẢO TRÂM

LỜI CAM ĐOAN

Chúng tôi cam đoan đây là công trình nghiên cứu của riêng chúng tôi, do chúng tôi tự thực hiện, không sao chép, vay mượn từ các công trình nghiên cứu khoa học khác. Đảm bảo mọi tài liệu tham khảo đều được trích dẫn, ghi chú đầy đủ.

Đồ án tốt nghiệp với đề tài "HỆ THỐNG CHAT BẢO MẬT (MÃ HÓA AES/RSA)" được thực hiện dưới sự hướng dẫn của ThS. CAO HOÀNG KHẢI, Khoa Công nghệ Thông tin, Trường Đại học Văn Hiến.

Toàn bộ nội dung trình bày trong đồ án này là sản phẩm của chúng tôi, được thực hiện nghiêm túc và trung thực. Các thông tin, số liệu, kết quả trong đồ án là hoàn toàn trung thực và chưa được công bố trong bất kỳ công trình nào khác.

Mọi sự sao chép không hợp lệ, vi phạm quy chế nhà trường, chúng tôi xin hoàn toàn chịu trách nhiệm.

Tp.Hồ Chí Minh, ngày tháng năm 2025

Sinh viên thực hiện
(Ký tên và ghi rõ họ tên)

PHẠM VĂN TÙNG

HUỲNH THỊ BẢO TRÂM

NHẬN XÉT CỦA GIẢNG VIÊN HƯỚNG DẪN

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Tp.Hồ Chí Minh, ngày tháng năm 2025

Giảng viên hướng dẫn

(Ký tên và ghi rõ họ tên)

ThS. CAO HOÀNG KHẢI

MỤC LỤC

TOC \h \o "1-3"HYPERLINK "" \l "_Toc223951007"Chương 1. TỔNG QUAN VỀ HỆ THỐNG CHAT BẢO MẬT.....	PAGEREF _Toc223951007 \h 3
1.1 Bối cảnh và nhu cầu thực tiễn.....	3
1.2 Khảo sát các hệ thống chat hiện có.....	3
1.2.1 Các ứng dụng chat thương mại phổ biến.....	3
1.2.2 Hạn chế của các giải pháp hiện có.....	3
1.3 Giải pháp đề xuất.....	3
1.4 Phạm vi và giới hạn của đề tài.....	4
Chương 2. CƠ SỞ LÝ THUYẾT.....	5
2.1 Mật mã học và mã hóa dữ liệu.....	5
2.1.1 Khái niệm cơ bản.....	5
2.1.2 Thuật toán AES (Advanced Encryption Standard).....	5
2.1.3 Thuật toán RSA (Rivest–Shamir–Adleman).....	5
2.1.4 Kết hợp RSA và AES (Hybrid Encryption).....	5
2.2 Bảo mật kết nối với SSL/TLS.....	6
2.2.1 Tổng quan về SSL/TLS.....	6
2.2.2 Chứng thực số và Certificate Authority (CA).....	6
2.3 Mô hình Client-Server.....	6
2.4 Công nghệ và môi trường phát triển.....	6
2.4.1 Ngôn ngữ C# và nền tảng .NET.....	7
2.4.2 Windows Forms (WinForms).....	7
2.4.3 MySQL và quản lý cơ sở dữ liệu.....	7
Chương 3. PHÂN TÍCH VÀ THIẾT KẾ HỆ THỐNG.....	8
3.1 Yêu cầu chức năng.....	8
3.1.1 Yêu cầu phía Server.....	8
3.1.2 Yêu cầu phía Client.....	8
3.2 Yêu cầu phi chức năng.....	8
3.3 Thiết kế kiến trúc hệ thống.....	8
3.3.1 Kiến trúc tổng thể.....	8
3.3.2 Luồng xác thực kết nối.....	9
3.3.3 Giao thức trao đổi tin nhắn.....	9
3.4 Thiết kế cơ sở dữ liệu.....	9
3.5 So sánh các giải pháp mã hóa.....	10
Chương 4. CÀI ĐẶT VÀ THỰC NGHIỆM.....	11
4.1 Môi trường triển khai.....	11

4.1.1 Yêu cầu phần cứng và phần mềm.....	11
4.1.2 Cấu hình Server và chứng chỉ SSL.....	11
4.2 Cài đặt các chức năng chính.....	11
4.2.1 Cơ chế xác thực TLS Mutual.....	11
4.2.2 Cơ chế mã hóa RSA + AES.....	11
4.2.3 Chức năng truyền file.....	12
4.2.4 Lưu trữ lịch sử chat.....	12
4.3 Giao diện ứng dụng.....	12
4.3.1 Giao diện Server.....	12
4.3.2 Giao diện Client – Đăng nhập.....	12
4.3.3 Giao diện Client – Cửa sổ chat chính.....	12
4.4 Kiểm thử hệ thống.....	13
4.4.1 Kiểm thử chức năng.....	13
4.4.2 Kiểm thử bảo mật.....	13
4.4.3 Kiểm thử hiệu năng.....	13
4.5 Đánh giá kết quả.....	13
A Cấu hình Server (App.config).....	16
B Cấu hình Client (App.config).....	16
C Hướng dẫn triển khai nhanh.....	16

DANH MỤC CÁC BẢNG BIỂU, HÌNH VẼ

Bảng 3.1 So sánh các giải pháp mã hóa	Trang
Bảng 3.2 Cấu trúc bảng Users trong cơ sở dữ liệu	Trang
Bảng 3.3 Cấu trúc bảng Messages trong cơ sở dữ liệu	Trang
Hình 1.1 Mô hình ứng dụng chat bảo mật tổng quát	Trang
Hình 2.1 Sơ đồ hoạt động của thuật toán AES	Trang
Hình 2.2 Sơ đồ hoạt động của thuật toán RSA	Trang
Hình 2.3 Mô hình SSL/TLS Handshake	Trang
Hình 3.1 Sơ đồ kiến trúc tổng thể hệ thống	Trang
Hình 3.2 Sơ đồ Use Case tổng quát	Trang
Hình 4.1 Giao diện đăng nhập Client	Trang
Hình 4.2 Giao diện cửa sổ chat chính	Trang
Hình 4.3 Giao diện quản lý Server	Trang

DANH MỤC CÁC TỪ VIẾT TẮT – THUẬT NGỮ ANH – VIỆT

AES	Advanced Encryption Standard	Tiêu chuẩn mã hóa tiên tiến
API	Application Programming Interface	Giao diện lập trình ứng dụng
CA	Certificate Authority	Tổ chức chứng thực số
CSDL	Cơ sở dữ liệu	Database
DTO	Data Transfer Object	Đối tượng truyền dữ liệu
GUI	Graphical User Interface	Giao diện người dùng đồ họa
IP	Internet Protocol	Giao thức Internet
LAN	Local Area Network	Mạng máy tính cục bộ
PFX	Personal Information Exchange	Định dạng trao đổi thông tin cá nhân
RSA	Rivest–Shamir–Adleman	Thuật toán mã hóa bất đối xứng RSA
SSL	Secure Sockets Layer	Tầng cổng bảo mật
TCP	Transmission Control Protocol	Giao thức điều khiển truyền tải
TLS	Transport Layer Security	Bảo mật tầng truyền tải
UI	User Interface	Giao diện người dùng
WinForms	Windows Forms	Nền tảng giao diện Windows Forms (.NET)

MỞ ĐẦU

1. Lý do chọn đề tài

Trong thời đại công nghệ số 4.0, nhu cầu trao đổi thông tin trực tuyến ngày càng trở nên thiết yếu trong mọi lĩnh vực của cuộc sống. Các ứng dụng nhắn tin như Zalo, Telegram, hay Messenger đã trở thành công cụ không thể thiếu trong giao tiếp hàng ngày. Tuy nhiên, một vấn đề đặt ra là tính bảo mật của dữ liệu trong quá trình truyền tải qua mạng – đặc biệt là trên môi trường mạng nội bộ (LAN) lẫn Internet.

Hầu hết các hệ thống chat phổ biến hiện nay đều được xây dựng dưới dạng dịch vụ điện toán đám mây, dữ liệu người dùng có thể bị thu thập hoặc lộ lọt. Đối với các tổ chức, doanh nghiệp hay cơ sở giáo dục, việc có một hệ thống chat tự chủ, bảo mật, chạy trên hạ tầng nội bộ là điều vô cùng cần thiết.

Xuất phát từ thực tiễn đó, nhóm chúng em quyết định nghiên cứu và xây dựng đề tài "Hệ thống Chat bảo mật (Mã hóa AES/RSA)" nhằm cung cấp một giải pháp truyền thông bảo mật, đáng tin cậy, có khả năng triển khai linh hoạt trên mạng LAN hoặc Internet.

2. Mục đích nghiên cứu

Mục đích chính của đề tài là thiết kế và xây dựng một hệ thống chat bảo mật hoàn chỉnh, trong đó dữ liệu tin nhắn được mã hóa end-to-end bằng kết hợp hai thuật toán RSA và AES. Hệ thống đảm bảo chỉ người nhận hợp lệ mới có thể giải mã và đọc được nội dung tin nhắn.

3. Đối tượng nghiên cứu

Đối tượng nghiên cứu của đề tài bao gồm: các thuật toán mã hóa đối xứng (AES) và bất đối xứng (RSA); giao thức bảo mật SSL/TLS và cơ chế chứng thực CA; kiến trúc lập trình mạng Client-Server; ngôn ngữ C# và nền tảng .NET WinForms.

4. Nhiệm vụ nghiên cứu

Để đạt được mục đích trên, nhóm đặt ra các nhiệm vụ cụ thể như sau:

- Nghiên cứu lý thuyết về các thuật toán mã hóa AES, RSA và giao thức SSL/TLS.
- Thiết kế kiến trúc hệ thống Client-Server với cơ chế xác thực chứng chỉ số (CA).
- Xây dựng cơ sở dữ liệu MySQL lưu trữ tài khoản người dùng và lịch sử chat.
- Lập trình Server WinForms quản lý kết nối, cấp phát tài khoản và điều phối tin nhắn.
- Lập trình Client WinForms hỗ trợ đăng nhập, gửi/nhận tin nhắn và truyền file có mã hóa.
- Kiểm thử và đánh giá hiệu năng của hệ thống trên môi trường mạng LAN.

5. Phương pháp nghiên cứu

Nhóm sử dụng kết hợp các phương pháp: nghiên cứu tài liệu (sách giáo khoa, bài báo khoa học, tài liệu kỹ thuật Microsoft); phân tích và thiết kế hệ thống theo mô hình Client-Server; lập trình thực nghiệm bằng C#/.NET; kiểm thử chức năng và bảo mật.

6. Kết quả đạt được

Sau quá trình nghiên cứu và thực hiện, nhóm đã đạt được các kết quả chính:

- Hoàn thành hệ thống Server quản lý người dùng, cấp phát tài khoản và chứng chỉ SSL.
- Hoàn thành ứng dụng Client với đầy đủ chức năng: đăng nhập, chat, truyền file, lưu lịch sử.
- Triển khai thành công cơ chế mã hóa kết hợp RSA + AES cho từng phiên chat.
- Xác thực kết nối an toàn bằng SSL/TLS với chứng chỉ CA tự cấp.
- Kiểm thử thành công trên mạng LAN với nhiều client kết nối đồng thời.

7. Kết cấu của đồ án

Ngoài phần Mở đầu và Kết luận, đồ án được tổ chức thành 4 chương chính:

- Chương 1: Tổng quan về hệ thống chat bảo mật – Giới thiệu bối cảnh, nhu cầu thực tiễn và khảo sát các hệ thống chat hiện có.
- Chương 2: Cơ sở lý thuyết – Trình bày lý thuyết về mã hóa AES, RSA, giao thức SSL/TLS, mô hình Client-Server và công nghệ sử dụng.
- Chương 3: Phân tích và thiết kế hệ thống – Đặc tả yêu cầu, thiết kế kiến trúc, cơ sở dữ liệu và luồng xử lý.
- Chương 4: Cài đặt và thực nghiệm – Trình bày chi tiết việc cài đặt, giao diện và kết quả kiểm thử hệ thống.

Chương 1. TỔNG QUAN VỀ HỆ THỐNG CHAT BẢO MẬT

1.1 Bối cảnh và nhu cầu thực tiễn

Trong bối cảnh chuyển đổi số diễn ra mạnh mẽ, các tổ chức ngày càng phụ thuộc vào hệ thống thông tin nội bộ để vận hành. Nhu cầu trao đổi thông tin nhanh chóng, bảo mật giữa các thành viên trong cùng một tổ chức là điều tất yếu. Các ứng dụng nhắn tin thương mại như Zalo, Telegram hay Microsoft Teams dù tiện lợi nhưng đặt ra nhiều lo ngại về quyền riêng tư, kiểm soát dữ liệu và phụ thuộc vào hạ tầng bên thứ ba.

Đặc biệt đối với các đơn vị giáo dục, nghiên cứu hoặc doanh nghiệp vừa và nhỏ, việc triển khai một hệ thống chat tự chủ trên hạ tầng nội bộ giúp kiểm soát hoàn toàn luồng thông tin, tránh rò rỉ dữ liệu nhạy cảm ra bên ngoài. Đây chính là động lực thúc đẩy nhóm thực hiện đề tài này.

1.2 Khảo sát các hệ thống chat hiện có

1.2.1 Các ứng dụng chat thương mại phổ biến

Hiện nay trên thị trường có nhiều ứng dụng chat phổ biến như Zalo, Telegram, WhatsApp, Signal và Microsoft Teams. Mỗi ứng dụng có những ưu điểm riêng nhưng đều có chung một đặc điểm là dữ liệu được lưu trữ trên máy chủ của nhà cung cấp dịch vụ. Điều này có nghĩa là người dùng phải tin tưởng hoàn toàn vào chính sách bảo mật của bên thứ ba.

Signal là ứng dụng được đánh giá cao nhất về bảo mật nhờ sử dụng giao thức Signal Protocol với mã hóa đầu cuối (end-to-end encryption). Tuy nhiên, Signal vẫn yêu cầu kết nối Internet và phụ thuộc vào hạ tầng đám mây của nhà phát triển.

1.2.2 Hạn chế của các giải pháp hiện có

Các ứng dụng chat thương mại tồn tại một số hạn chế đáng kể khi áp dụng vào môi trường nội bộ:

- Phụ thuộc vào kết nối Internet và máy chủ của nhà cung cấp.
- Không thể kiểm soát hoàn toàn dữ liệu nội bộ của tổ chức.
- Chi phí bản quyền cao đối với phiên bản doanh nghiệp.
- Không linh hoạt trong việc tùy chỉnh theo yêu cầu đặc thù của tổ chức.
- Nguy cơ mất dữ liệu khi nhà cung cấp ngừng dịch vụ hoặc bị tấn công.

1.3 Giải pháp đề xuất

Từ những phân tích trên, nhóm đề xuất xây dựng hệ thống chat bảo mật tự chủ với các đặc điểm nổi bật:

- Triển khai hoàn toàn trên hạ tầng nội bộ (LAN) hoặc mạng riêng, không phụ thuộc Internet.

- Mã hóa toàn bộ nội dung trao đổi bằng kết hợp RSA và AES.
- Xác thực kết nối an toàn bằng chứng chỉ số SSL/TLS do CA nội bộ cấp.
- Quản lý tập trung tài khoản người dùng qua Server, hỗ trợ DTO để bảo mật dữ liệu.
- Lưu trữ lịch sử chat tại máy Client để bảo vệ quyền riêng tư người dùng.

1.4 Phạm vi và giới hạn của đề tài

Đề tài tập trung vào việc xây dựng hệ thống chat bảo mật cho môi trường mạng LAN nội bộ, có thể mở rộng ra Internet khi cấu hình cổng (port forwarding). Hệ thống hỗ trợ giao tiếp văn bản và truyền file giữa hai người dùng (1-1) và nhiều người dùng (nhóm chat). Phiên bản hiện tại chưa hỗ trợ gọi thoại, gọi video hay tích hợp với các nền tảng bên ngoài.

Chương 2. CƠ SỞ LÝ THUYẾT

2.1 Mật mã học và mã hóa dữ liệu

2.1.1 Khái niệm cơ bản

Mật mã học (Cryptography) là ngành khoa học nghiên cứu các kỹ thuật bảo mật thông tin bằng cách biến đổi dữ liệu sang dạng không thể đọc được (bản mã - ciphertext) để chỉ những người có quyền mới có thể giải mã về dạng ban đầu (bản rõ - plaintext). Mã hóa là quá trình chuyển đổi bản rõ thành bản mã, còn giải mã là quá trình ngược lại.

Có hai loại mã hóa chính: mã hóa đối xứng (Symmetric Encryption) sử dụng cùng một khóa cho cả hai quá trình mã hóa và giải mã; và mã hóa bất đối xứng (Asymmetric Encryption) sử dụng cặp khóa công khai và khóa bí mật.

2.1.2 Thuật toán AES (Advanced Encryption Standard)

AES là tiêu chuẩn mã hóa đối xứng được Viện Tiêu chuẩn và Công nghệ Hoa Kỳ (NIST) công bố vào năm 2001, thay thế cho DES. AES hoạt động trên khối dữ liệu 128-bit và hỗ trợ ba độ dài khóa: 128, 192 và 256 bit.

Trong đề tài này, nhóm sử dụng AES-256 với chế độ CBC (Cipher Block Chaining) kết hợp với vector khởi tạo ngẫu nhiên (IV – Initialization Vector) để đảm bảo tính ngẫu nhiên trong quá trình mã hóa. AES được chọn để mã hóa nội dung tin nhắn vì tốc độ xử lý nhanh và hiệu quả cao với dữ liệu lớn.

Quá trình mã hóa AES bao gồm nhiều vòng (rounds) lặp, mỗi vòng thực hiện bốn phép biến đổi: SubBytes (thay thế byte), ShiftRows (dịch hàng), MixColumns (trộn cột) và AddRoundKey (cộng khóa vòng). Với khóa 256-bit, AES thực hiện 14 vòng lặp, cung cấp độ bảo mật rất cao.

2.1.3 Thuật toán RSA (Rivest–Shamir–Adleman)

RSA là thuật toán mã hóa bất đối xứng được phát minh bởi Ron Rivest, Adi Shamir và Leonard Adleman vào năm 1977. RSA dựa trên bài toán phân tích số nguyên thành thừa số nguyên tố – một bài toán được coi là rất khó giải trong thực tế với các số đủ lớn.

Mỗi người dùng trong hệ thống có một cặp khóa RSA gồm: khóa công khai (Public Key) có thể chia sẻ tự do và khóa bí mật (Private Key) chỉ người dùng mới biết. Trong đề tài này, RSA được sử dụng để trao đổi khóa AES một cách an toàn giữa các bên: người gửi mã hóa khóa AES bằng khóa công khai của người nhận, người nhận dùng khóa bí mật của mình để giải mã lấy lại khóa AES.

2.1.4 Kết hợp RSA và AES (Hybrid Encryption)

Mã hóa lai (Hybrid Encryption) là kỹ thuật kết hợp ưu điểm của cả hai loại mã hóa: RSA đảm bảo việc trao đổi khóa an toàn, còn AES đảm bảo hiệu suất mã hóa dữ liệu cao. Quy trình hoạt động như sau:

- Người gửi tạo một khóa AES ngẫu nhiên cho mỗi phiên chat.
- Khóa AES được mã hóa bằng khóa RSA công khai của người nhận.
- Nội dung tin nhắn được mã hóa bằng khóa AES vừa tạo.
- Người nhận dùng khóa RSA bí mật để giải mã lấy khóa AES, sau đó dùng AES giải mã nội dung.

2.2 Bảo mật kết nối với SSL/TLS

2.2.1 Tổng quan về SSL/TLS

SSL (Secure Sockets Layer) và phiên bản kế thừa TLS (Transport Layer Security) là các giao thức mật mã được thiết kế để cung cấp bảo mật truyền thông qua mạng máy tính. TLS đảm bảo ba thuộc tính quan trọng: tính bí mật (confidentiality), tính toàn vẹn (integrity) và tính xác thực (authentication).

Trong hệ thống, TLS được áp dụng ở tầng kết nối TCP giữa Client và Server. Điều này có nghĩa là ngay cả khi kẻ tấn công chặn được gói tin trên đường mạng, họ cũng không thể đọc được nội dung do toàn bộ dữ liệu đã được mã hóa ở tầng TLS – và thêm một lớp mã hóa AES/RSA ở tầng ứng dụng.

2.2.2 Chứng thực số và Certificate Authority (CA)

Chứng thực số (Digital Certificate) là tài liệu điện tử xác minh danh tính của một thực thể trong hệ thống mạng. Một CA (Certificate Authority) là tổ chức đáng tin cậy có trách nhiệm cấp phát và quản lý các chứng chỉ số.

Trong đề tài, nhóm xây dựng một CA nội bộ (Self-signed CA) để cấp chứng chỉ cho Server và từng Client. Server giữ chứng chỉ của CA để xác thực các Client kết nối đến. Mỗi Client được cấp một chứng chỉ riêng dạng PFX (PKCS#12) chứa cả khóa bí mật. Quá trình này đảm bảo chỉ những Client được cấp phép mới có thể kết nối đến Server.

2.3 Mô hình Client-Server

Mô hình Client-Server là kiến trúc phân tán trong đó Server cung cấp dịch vụ và Client gửi yêu cầu sử dụng dịch vụ đó. Trong hệ thống chat bảo mật này, Server đóng vai trò trung tâm điều phối: quản lý danh sách người dùng trực tuyến, định tuyến tin nhắn giữa các Client và lưu trữ thông tin tài khoản trong cơ sở dữ liệu MySQL.

Giao thức truyền thông sử dụng TCP (Transmission Control Protocol) đảm bảo dữ liệu được truyền đúng thứ tự và không bị mất mát. Mỗi Client duy trì một kết nối TCP bền vững với Server trong suốt phiên làm việc.

2.4 Công nghệ và môi trường phát triển

2.4.1 Ngôn ngữ C# và nền tảng .NET

C# là ngôn ngữ lập trình hướng đối tượng hiện đại được Microsoft phát triển, chạy trên nền tảng .NET. Nền tảng .NET cung cấp thư viện phong phú hỗ trợ lập trình mạng (System.Net), mã hóa (System.Security.Cryptography) và giao diện WinForms – tất cả đều được sử dụng trong đề tài này.

2.4.2 Windows Forms (WinForms)

WinForms là framework phát triển giao diện đồ họa (GUI) cho ứng dụng Windows, là một phần của .NET. WinForms cung cấp bộ điều khiển (controls) phong phú và mô hình lập trình event-driven trực quan, phù hợp để xây dựng ứng dụng chat desktop với giao diện thân thiện.

2.4.3 MySQL và quản lý cơ sở dữ liệu

MySQL là hệ quản trị cơ sở dữ liệu quan hệ (RDBMS) mã nguồn mở phổ biến nhất thế giới. Trong đề tài, MySQL được sử dụng để lưu trữ thông tin tài khoản người dùng và metadata của tin nhắn. Kết nối từ ứng dụng C# đến MySQL được thực hiện qua thư viện MySql.Data (MySQL Connector/NET).

Chương 3. PHÂN TÍCH VÀ THIẾT KẾ HỆ THỐNG

3.1 Yêu cầu chức năng

3.1.1 Yêu cầu phía Server

Server đóng vai trò là thành phần trung tâm của hệ thống, cần đáp ứng các yêu cầu chức năng sau:

- Khởi động và lắng nghe kết nối từ Client trên cổng 8443 với bảo mật TLS.
- Xác thực chứng chỉ Client khi thiết lập kết nối (Mutual TLS).
- Quản lý cơ sở dữ liệu MySQL: tạo, xóa, cập nhật tài khoản người dùng.
- Định tuyến tin nhắn và file giữa các Client đang kết nối.
- Hiện thị danh sách Client đang trực tuyến trên giao diện quản lý.
- Cung cấp công cụ phát hành chứng chỉ Client (Server.Tools).

3.1.2 Yêu cầu phía Client

Client là ứng dụng người dùng cuối, cần đáp ứng các yêu cầu chức năng:

- Đăng nhập bằng tài khoản và chứng chỉ TLS được Server cấp phát.
- Hiện thị danh sách người dùng trực tuyến.
- Gửi và nhận tin nhắn văn bản được mã hóa AES/RSA.
- Truyền và nhận file qua kết nối bảo mật.
- Lưu trữ lịch sử chat trên máy Client theo từng cuộc hội thoại.
- Hỗ trợ chat nhóm với nhiều người dùng đồng thời.

3.2 Yêu cầu phi chức năng

Ngoài các yêu cầu chức năng, hệ thống cần đáp ứng các yêu cầu phi chức năng quan trọng:

- Bảo mật: Toàn bộ dữ liệu truyền tải phải được mã hóa. Không cho phép kết nối không có chứng chỉ hợp lệ.
- Hiệu năng: Hỗ trợ tối thiểu 20 Client kết nối đồng thời trên mạng LAN.
- Độ tin cậy: Kết nối TCP đảm bảo không mất gói tin. Tự động ngắt kết nối Client không phản hồi.
- Khả năng sử dụng: Giao diện WinForms trực quan, dễ sử dụng cho người dùng không chuyên về kỹ thuật.

3.3 Thiết kế kiến trúc hệ thống

3.3.1 Kiến trúc tổng thể

Hệ thống được tổ chức thành ba project độc lập trong cùng một Solution .NET:

- Server.WinForms: Ứng dụng Server chạy trên máy tính đóng vai trò máy chủ, lắng nghe kết nối, quản lý người dùng và điều phối tin nhắn.
- Client.WinForms: Ứng dụng Client chạy trên máy tính của người dùng, giao tiếp với Server qua kết nối TLS.
- Shared_Core: Thư viện dùng chung chứa các DTO (Data Transfer Object), giao thức truyền thông và các lớp tiện ích mã hóa.

- Server.Tools: Công cụ dòng lệnh hỗ trợ quản trị viên: khởi tạo CSDL, phát hành chứng chỉ Client và xuất PFX.

3.3.2 Luồng xác thực kết nối

Quá trình thiết lập kết nối an toàn giữa Client và Server diễn ra qua các bước sau: Client khởi tạo kết nối TCP đến địa chỉ Server (IP:8443); hai bên thực hiện TLS Handshake, trong đó Server gửi chứng chỉ SSL của mình và yêu cầu chứng chỉ từ Client; Client gửi chứng chỉ PFX được cấp bởi CA nội bộ; Server xác minh chứng chỉ Client với chứng chỉ CA. Nếu xác thực thành công, kênh truyền thông TLS được thiết lập và Client gửi DTO đăng nhập (username/password) qua kênh bảo mật này.

3.3.3 Giao thức trao đổi tin nhắn

Sau khi đăng nhập thành công, mỗi tin nhắn giữa hai người dùng trải qua quy trình mã hóa như sau: Người gửi tạo một khóa AES-256 và IV ngẫu nhiên cho tin nhắn; mã hóa nội dung tin nhắn bằng AES; mã hóa khóa AES bằng khóa RSA công khai của người nhận; đóng gói thành DTO gồm: dữ liệu mã hóa AES, khóa AES đã mã hóa RSA, IV và định danh người gửi/nhận; gửi DTO qua kênh TLS đến Server; Server định tuyến DTO đến Client đích mà không giải mã nội dung; Client nhận dùng khóa RSA bí mật giải mã khóa AES rồi giải mã nội dung.

3.4 Thiết kế cơ sở dữ liệu

Cơ sở dữ liệu MySQL (lan_stream) gồm các bảng chính sau:

Bảng 3.1. Cấu trúc bảng Users

Tên cột	Kiểu dữ liệu	Ràng buộc	Mô tả
id	INT	PK, AUTO	Khóa chính
username	VARCHAR(50)	UNIQUE, NN	Tên đăng nhập
password_hash	VARCHAR(255)	NOT NULL	Mật khẩu đã băm
display_name	VARCHAR(100)		Tên hiển thị
public_key	TEXT		Khóa RSA công khai
created_at	DATETIME		Ngày tạo tài khoản
is_active	TINYINT(1)	DEFAULT 1	Trạng thái hoạt động

Bảng 3.2. Cấu trúc bảng Messages

Tên cột	Kiểu dữ liệu	Ràng buộc	Mô tả
id	BIGINT	PK, AUTO	Khóa chính

sender_id	INT	FK→Users	Người gửi
receiver_id	INT	FK→Users	Người nhận
content_enc	LONGBLOB	NOT NULL	Nội dung đã mã hóa AES
aes_key_enc	BLOB	NOT NULL	Khóa AES đã mã hóa RSA
iv	BLOB	NOT NULL	Vector khởi tạo AES
sent_at	DATETIME		Thời gian gửi
is_file	TINYINT(1)	DEFAULT 0	Có phải file không

3.5 So sánh các giải pháp mã hóa

Bảng 3.3. So sánh các giải pháp mã hóa

Tiêu chí	AES-256	RSA-2048	DES/3DES	Hybrid (Đề tài)
Tốc độ	Rất nhanh	Chậm	Chậm	Nhanh
Độ bảo mật	Rất cao	Cao	Thấp/Trung bình	Rất cao
Trao đổi khóa	Khó (cần kênh an toàn)	Dễ (khóa công khai)	Khó	Dễ (RSA+AES)
Phù hợp dữ liệu lớn	Có	Không	Có	Có
Áp dụng trong đề tài	Mã hóa nội dung	Mã hóa khóa AES	Không dùng	Giải pháp chính

Chương 4. CÀI ĐẶT VÀ THỰC NGHIỆM

4.1 Môi trường triển khai

4.1.1 Yêu cầu phần cứng và phần mềm

Để triển khai hệ thống, môi trường cần đáp ứng các yêu cầu tối thiểu sau:

- Phần cứng: CPU Intel Core i3 trở lên, RAM tối thiểu 4GB, dung lượng ổ cứng 500MB trống.
- Hệ điều hành: Windows 10/11 64-bit hoặc Windows Server 2019.
- Phần mềm: .NET 6.0 Runtime trở lên, MySQL Server 8.0, MySQL Connector/NET.
- Mạng: Kết nối LAN 100Mbps trở lên giữa các máy Client và Server.

4.1.2 Cấu hình Server và chứng chỉ SSL

Trước khi khởi động hệ thống, quản trị viên cần thực hiện các bước cấu hình ban đầu. Đầu tiên sử dụng công cụ Server.Tools để khởi tạo cơ sở dữ liệu với lệnh: seed "<connection_string>". Tiếp theo phát hành chứng chỉ Client cho từng người dùng bằng lệnh issue-client và xuất file PFX bằng export-pfx. File PFX này được phân phối đến máy Client cùng với thông tin tài khoản.

Cấu hình kết nối Server được đặt trong file App.config: địa chỉ IP lắng nghe (0.0.0.0), cổng 8443, đường dẫn chứng chỉ CA và chứng chỉ Server PFX, chuỗi kết nối MySQL.

4.2 Cài đặt các chức năng chính

4.2.1 Cơ chế xác thực TLS Mutual

Kết nối TLS được thiết lập thông qua lớp SslStream trong namespace System.Net.Security của .NET. Server cấu hình SslStream yêu cầu Client phải cung cấp chứng chỉ và xác thực chứng chỉ đó với chứng chỉ CA nội bộ. Thuộc tính ClientCertificateRequired được đặt thành true, và callback RemoteCertificateValidationCallback kiểm tra chuỗi chứng chỉ của Client.

Client tải chứng chỉ PFX từ đường dẫn cấu hình, gửi kèm trong quá trình TLS Handshake. Sau khi TLS Handshake hoàn tất, toàn bộ dữ liệu trao đổi qua SslStream đều được mã hóa tự động bởi TLS.

4.2.2 Cơ chế mã hóa RSA + AES

Mỗi Client khi đăng nhập thành công sẽ gửi khóa RSA công khai của mình lên Server. Server lưu khóa này vào CSDL và phân phối cho các Client khác khi cần. Khi Client A muốn gửi tin nhắn cho Client B, ứng dụng thực hiện các bước: tạo khóa AES-256 và IV ngẫu nhiên bằng System.Security.Cryptography.Aes; mã hóa nội dung tin nhắn

bằng AES (chế độ CBC); lấy khóa RSA công khai của Client B từ Server; mã hóa khóa AES bằng RSA (thuật toán OAEP SHA-256); đóng gói thành đối tượng MessageDto và gửi qua SslStream.

Phía Client B nhận được MessageDto, sử dụng khóa RSA bí mật (lưu an toàn trên máy Client) để giải mã khóa AES, sau đó dùng khóa AES và IV để giải mã nội dung tin nhắn. Quá trình này đảm bảo kể cả Server cũng không thể đọc được nội dung tin nhắn giữa hai Client.

4.2.3 Chức năng truyền file

Chức năng truyền file sử dụng cùng cơ chế mã hóa với tin nhắn văn bản. File được đọc thành mảng byte, mã hóa AES và đóng gói trong FileDto bao gồm: tên file, kích thước gốc, dữ liệu đã mã hóa, khóa AES đã mã hóa RSA và IV. Server định tuyến FileDto đến Client đích tương tự như tin nhắn. Để xử lý file lớn, dữ liệu được chia thành các chunk 4KB và truyền tuần tự.

4.2.4 Lưu trữ lịch sử chat

Lịch sử chat được lưu trữ cục bộ tại máy Client dưới dạng file JSON mã hóa, tổ chức theo từng cặp người dùng. Mỗi mục lịch sử bao gồm: thời gian gửi, người gửi, nội dung đã giải mã (được mã hóa lại bằng khóa cục bộ trên máy Client). Khi Client khởi động, ứng dụng tự động tải lịch sử chat từ file cục bộ và hiển thị vào cửa sổ hội thoại tương ứng.

4.3 Giao diện ứng dụng

4.3.1 Giao diện Server

Giao diện Server (Server.WinForms) hiển thị bảng điều khiển chính bao gồm: nút Start/Stop Server, danh sách Client đang kết nối (hiển thị tên đăng nhập, địa chỉ IP và thời gian kết nối), log hoạt động theo thời gian thực và số liệu thống kê kết nối. Quản trị viên có thể ngắt kết nối một Client cụ thể hoặc gửi thông báo hệ thống đến tất cả Client.

4.3.2 Giao diện Client – Đăng nhập

Màn hình đăng nhập (LoginForm) yêu cầu người dùng nhập tên đăng nhập và mật khẩu. Thông tin này được gửi qua kênh TLS dưới dạng LoginDto đến Server. Server kiểm tra thông tin đăng nhập với CSDL (mật khẩu được băm SHA-256). Nếu xác thực thành công, Server trả về thông tin phiên và danh sách người dùng trực tuyến.

4.3.3 Giao diện Client – Cửa sổ chat chính

Cửa sổ chat chính (MainChatForm) gồm: danh sách người dùng trực tuyến phía bên trái, vùng hiển thị tin nhắn của cuộc hội thoại đang chọn ở giữa, ô nhập tin nhắn và nút

gửi ở phía dưới. Tin nhắn được hiển thị phân biệt màu sắc giữa tin nhắn gửi và nhận. Người dùng có thể kéo thả file vào cửa sổ chat để gửi file, hoặc nhấn nút đính kèm để chọn file từ hệ thống.

4.4 Kiểm thử hệ thống

4.4.1 Kiểm thử chức năng

Nhóm tiến hành kiểm thử các chức năng chính theo phương pháp kiểm thử hộp đen (Black-box Testing). Kết quả kiểm thử cho thấy tất cả các chức năng cốt lõi hoạt động đúng như thiết kế: đăng nhập thành công/thất bại, gửi/nhận tin nhắn, truyền file, lưu và tải lịch sử chat, ngắt kết nối và kết nối lại.

4.4.2 Kiểm thử bảo mật

Nhóm thực hiện kiểm thử bảo mật bằng cách sử dụng công cụ Wireshark để bắt gói tin trên mạng LAN trong khi hai Client đang chat. Kết quả cho thấy toàn bộ dữ liệu truyền tải đều ở dạng mã hóa, không thể đọc được nội dung thực sự của tin nhắn. Kiểm thử kết nối không có chứng chỉ hợp lệ xác nhận Server từ chối kết nối và ghi log sự kiện.

4.4.3 Kiểm thử hiệu năng

Kiểm thử hiệu năng trên mạng LAN 100Mbps với 10 Client kết nối đồng thời cho kết quả: thời gian trễ trung bình của tin nhắn văn bản là dưới 50ms, tốc độ truyền file đạt trung bình 8-10MB/s. CPU Server sử dụng trung bình 15% khi có 10 Client hoạt động đồng thời. Các kết quả này đáp ứng tốt yêu cầu đề ra.

4.5 Đánh giá kết quả

Sau quá trình xây dựng và kiểm thử, hệ thống chat bảo mật đã đáp ứng được tất cả các yêu cầu chức năng và phi chức năng đề ra ban đầu. Các điểm mạnh của hệ thống bao gồm: bảo mật đa lớp (TLS + AES/RSA); tính tự chủ không phụ thuộc hạ tầng bên ngoài; giao diện thân thiện, dễ sử dụng; hiệu năng tốt trên môi trường LAN.

Tuy nhiên, hệ thống vẫn còn một số hạn chế cần cải thiện trong tương lai: chưa hỗ trợ gọi thoại/video; cơ chế quản lý khóa RSA chưa hỗ trợ thu hồi khóa (key revocation); chưa có cơ chế đồng bộ lịch sử chat giữa nhiều thiết bị của cùng một người dùng.

KẾT LUẬN VÀ ĐỀ NGHỊ

1. Kết luận

Đồ án tốt nghiệp với đề tài "Hệ thống Chat bảo mật (Mã hóa AES/RSA)" đã được thực hiện thành công, đáp ứng đầy đủ các yêu cầu đặt ra ban đầu. Nhóm đã xây dựng được một hệ thống chat bảo mật hoàn chỉnh, tự chủ, có thể triển khai trên môi trường mạng LAN nội bộ của tổ chức.

Những kết quả cụ thể đã đạt được trong quá trình thực hiện đồ án:

- Nghiên cứu và hiểu sâu về lý thuyết mã hóa AES-256, RSA-2048 và giao thức bảo mật TLS/SSL.
- Xây dựng thành công CA nội bộ và hệ thống phát hành chứng chỉ số cho Client.
- Cài đặt hoàn chỉnh cơ chế mã hóa lai (Hybrid Encryption) RSA + AES trên nền .NET C#.
- Phát triển ứng dụng Server WinForms quản lý kết nối đa luồng với MySQL.
- Phát triển ứng dụng Client WinForms với đầy đủ chức năng chat, truyền file và lịch sử.
- Kiểm thử xác nhận hệ thống bảo mật – không thể đọc nội dung tin nhắn khi bắt gói mạng.

Thông qua việc thực hiện đồ án, nhóm đã tích lũy được nhiều kiến thức và kinh nghiệm thực tiễn quý báu về lập trình mạng, bảo mật thông tin, và phát triển ứng dụng desktop. Đây là nền tảng vững chắc cho sự nghiệp phát triển phần mềm sau này.

2. Đề nghị

Dựa trên kết quả đạt được và những hạn chế hiện tại, nhóm đề nghị các hướng phát triển tiếp theo:

- Bổ sung tính năng gọi thoại và gọi video sử dụng giao thức WebRTC hoặc tích hợp thư viện chuyên dụng.
- Triển khai cơ chế Perfect Forward Secrecy (PFS) để tăng cường bảo mật: mỗi phiên sử dụng khóa phiên khác nhau.
- Xây dựng cơ chế thu hồi chứng chỉ (Certificate Revocation) khi tài khoản bị xóa hoặc bị khóa.
- Phát triển ứng dụng di động (Android/iOS) tương thích với hệ thống Server hiện tại.
- Tích hợp cơ chế xác thực hai yếu tố (2FA) để tăng cường bảo mật tài khoản.
- Nghiên cứu khả năng triển khai trên môi trường Docker để dễ dàng mở rộng và quản lý.

DANH MỤC TÀI LIỆU THAM KHẢO

Tiếng Việt:

- [1] Phan Đình Diệu (2002), Lý thuyết mật mã và an toàn thông tin, Nhà xuất bản Đại học Quốc gia Hà Nội, Hà Nội.
- [2] Nguyễn Xuân Huy (2008), Bảo mật hệ thống thông tin, Nhà xuất bản Thống Kê, Thành phố Hồ Chí Minh.
- [3] Nguyễn Đình Thuần, Nguyễn Việt Hùng (2015), Lập trình mạng với C#, Nhà xuất bản Thông tin và Truyền thông, Hà Nội.

Tiếng Anh:

- [1] Daemen, J., Rijmen, V. (2002), The Design of Rijndael: AES – The Advanced Encryption Standard, Springer-Verlag, Berlin.
- [2] Rivest, R.L., Shamir, A., Adleman, L. (1978), A Method for Obtaining Digital Signatures and Public-Key Cryptosystems, Communications of the ACM, 21(2), pp. 120-126.
- [3] Rescorla, E. (2018), The Transport Layer Security (TLS) Protocol Version 1.3, RFC 8446, IETF.
- [4] Price, M., Clark, A. (2019), C# in Depth, 4th Edition, Manning Publications, New York.
- [5] Stallings, W. (2022), Cryptography and Network Security: Principles and Practice, 8th Edition, Pearson, New Jersey.

Danh mục Website tham khảo:

- [1] Microsoft Documentation – System.Security.Cryptography:
<https://docs.microsoft.com/en-us/dotnet/api/system.security.cryptography>
- [2] NIST – Advanced Encryption Standard (AES):
<https://csrc.nist.gov/publications/detail/fips/197/final>
- [3] OpenSSL Documentation: <https://www.openssl.org/docs/>
- [4] MySQL Documentation – MySQL 8.0 Reference Manual:
<https://dev.mysql.com/doc/refman/8.0/en/>
- [5] Stack Overflow – SslStream Mutual Authentication:
<https://stackoverflow.com/questions/tagged/sslstream>

PHỤ LỤC

A Cấu hình Server (App.config)

Dưới đây là file cấu hình App.config của Server.WinForms:

```
ServerHost: 0.0.0.0 | ServerPort: 8443  
MySQLConnectionString: server=127.0.0.1;port=3306;database=lan_stream;  
CaCertPath: Certificates\ca\ca.crt  
ServerPfxPath: Certificates\server\server.pfx
```

B Cấu hình Client (App.config)

Dưới đây là file cấu hình App.config của Client.WinForms:

```
ServerHost: 127.0.0.1 | ServerPort: 8443  
CaCertPath: Certificates\ca.crt  
ClientPfxPath: Certificates\client.pfx
```

C Hướng dẫn triển khai nhanh

Các bước triển khai hệ thống trên môi trường LAN:

- Bước 1: Cài đặt MySQL Server 8.0 trên máy Server. Tạo database rỗng tên 'lan_stream'.
- Bước 2: Chạy Server.Tools với lệnh seed để khởi tạo cấu trúc bảng và tài khoản admin mặc định.
- Bước 3: Tạo CA nội bộ bằng OpenSSL. Tạo chứng chỉ Server và ký với CA.
- Bước 4: Khởi động Server.WinForms. Kiểm tra log xác nhận Server đang lắng nghe cổng 8443.
- Bước 5: Với mỗi Client, dùng Server.Tools lệnh issue-client để tạo chứng chỉ và export-pfx để xuất PFX.
- Bước 6: Phân phối file PFX và thông tin tài khoản đến Client. Cập nhật App.config với IP Server.
- Bước 7: Khởi động Client.WinForms và đăng nhập bằng tài khoản được cấp.